CloudDesk Technologies

Information Security Policy

1. Authority, scope and objectives

Document control

Policy ID: CD-ISP-001 | Version: 1.0 | Effective date: 2026-10-22 (fictional). Owner: Engineering Lead. Accountable approver: CTO (fictional role; approval not recorded). Review cycle: annually and after material changes; next scheduled review: 2027-10-22. Classification: SYNTHETIC / DEMO.

Status and assumptions

CloudDesk Technologies is a fictional 75-person B2B SaaS vendor. Every requirement in this document is a SYNTHETIC / DEMO assumption, not a verified operational fact. This model-authored policy requires user review and has not been approved. No SOC 2 report, ISO certification, external audit, legal compliance conclusion or operating effectiveness is claimed.

Scope and security objectives

Proposed scope covers employees, contractors, service identities, the hosted SaaS service, supporting cloud infrastructure, company endpoints, customer information and backups. Protect confidentiality, integrity and availability through proportionate risk decisions, controlled access, recoverability and accountable ownership. The Engineering Lead proposes measurable objectives annually; CTO approval and progress records are required before treating targets as agreed.

Roles and accountability

The CTO is accountable for security direction, resources and risk acceptance. The Engineering Lead coordinates this policy, the risk register and internal reviews. System owners identify assets, assess risks and track corrective actions. Platform Engineering implements assigned technical requirements. Managers coordinate training and personnel changes; all personnel report suspected exposure promptly. These are proposed responsibilities, not evidence of staffed teams or completed activities.

Information Security Policy

2. Risk, assets and information handling

Risk assessments and register

The Engineering Lead coordinates risk assessments at least annually and before material service changes or onboarding vendors with access to scoped information. System owners record threats, vulnerabilities, affected assets, likelihood, impact, existing safeguards and residual risk. Maintain a risk register with risk ID, owner, treatment, due date, acceptance decision and review date. The CTO approves residual risk acceptance; review open risks quarterly and escalate overdue high-impact actions.

Asset inventory and ownership

System owners maintain an inventory of scoped systems, devices, services, data stores and vendors, identifying owner, business purpose, classification and dependencies. Update the inventory on acquisition, material change and retirement. Inventory entries are expected records; this sample supplies no actual asset list.

Classification and handling

Use Public for material explicitly approved for public release; Internal for routine nonpublic business information; Confidential for customer data, contracts and sensitive business information; Restricted for credentials, private keys and highly sensitive security material. Owners assign the highest applicable class and review changes. Share nonpublic information only with authorized recipients through approved channels; verify recipients and limit copies. Never place secrets in source code, logs or support exports.

Retention and disposal

Owners propose retention schedules based on business need, customer commitments and applicable obligations, with review by the appropriate accountable role. Record approved periods and any holds before disposal. Restrict access during retention and use verified deletion or secure media disposal at end of life. This policy does not invent retention periods or backup schedules. Public marketing content may be stored unencrypted as permitted by the encryption policy; administrative and authentication traffic still require transport protection.

Information Security Policy

3. Access, encryption and supplier oversight

Access Control Policy reference

Apply access_control_policy.pdf (CloudDesk Access Control Policy): use unique user accounts; require multi-factor authentication for administrative access; review user access permissions every quarter; revoke terminated employee access within 24 hours. Managers and system owners coordinate requests, approvals and revocation records. This governance policy preserves those requirements and does not claim their implementation.

Encryption and Key Management Policy reference

Apply encryption_key_management_policy.pdf and its editable JSON, CD-ENC-001 v1.0. Require TLS 1.2 or TLS 1.3 for scoped transport and AES-256 at rest for scoped production storage and backups. Use managed KMS for production keys, rotate symmetric key-encryption keys at least every 12 months and retain older versions only while dependent data or backups require them. Follow its detailed grant, certificate, secrets and destruction requirements; no customer-managed keys or end-to-end encryption capability is assumed.

Security awareness and training

Managers arrange security awareness training at onboarding and annually thereafter, covering phishing, safe sharing, credential protection, incident reporting and classification. Provide role-specific guidance for privileged operators and developers when responsibilities change. The Engineering Lead tracks assigned training, attendance, completion and overdue follow-up. These are expected records, not claims of completed training.

Vendor management oversight

Before a vendor handles scoped information, the business owner documents data access, service criticality, security requirements, available assurance evidence and identified risks. Engineering Lead reviews the assessment and CTO accepts material residual risk before use. Define appropriate confidentiality, incident communication, access termination and data return or deletion terms in agreements. Reassess critical vendors annually and after material changes or incidents; track findings and exit dependencies. No vendor certifications or assurances are presumed.

Information Security Policy

4. Incidents, continuity and recovery governance

Incident reporting and coordination

Personnel promptly report suspected exposure or disruption to the Engineering Lead through the proposed internal reporting route; no live address or staffed response service is asserted. The Engineering Lead coordinates triage, severity, containment, evidence preservation and an incident record. CTO directs material escalation and authorizes external communications with relevant advice. Determine contractual and legal notification duties case by case; no universal notification deadline is asserted.

Incident records and learning

Record discovery time, affected assets and information, decisions, responders, containment, recovery and corrective actions. Restrict evidence access and preserve relevant logs and decision history. After significant incidents, the Engineering Lead coordinates lessons learned and assigns remediation owners and due dates, with CTO review. Suspected key compromise follows CD-ENC-001, including emergency access and key-recovery safeguards.

Business continuity and disaster recovery

System owners identify critical services, dependencies, disruption scenarios and recovery priorities. CTO approves proposed recovery time objectives (RTO) and recovery point objectives (RPO) after impact assessment; this sample asserts no numerical targets or availability guarantees. Maintain reviewed continuity and recovery procedures with responsibilities, dependencies and communication plans. Exercise continuity scenarios at least annually and after material changes, recording gaps and corrective actions.

Backup recovery oversight

Follow CD-ENC-001 for encrypted backups, backup-specific key grants and retention of keys needed for recovery. Test a representative encrypted restore at least quarterly and record integrity, authorized key access and outcome. Owners reconcile recovery results with approved continuity objectives and track gaps. Backup schedules, data retention periods and successful restore history are not asserted by this document.

Information Security Policy

5. Reviews, exceptions, records and enforcement

Internal security reviews

The Engineering Lead coordinates an annual internal review of policy requirements and expected evidence, reporting findings and corrective actions to the CTO. Track owners, due dates and closure evidence; review open findings quarterly. Preserve the quarterly access reviews and monthly KMS administrative and decrypt audit-event reviews required by the related policies. Internal review is not an independent audit or certification.

Exceptions and risk acceptance

Before deviation, the system owner records affected assets and data, requirement, rationale, risk, compensating safeguards, owner and expiry. Engineering Lead assesses and CTO approves or rejects. Proposed exceptions expire within 90 days and are reviewed monthly; renewal requires fresh assessment and approval. Emergency deviations require an incident record and CTO review by the next business day. CD-ENC-001 remains authoritative for encryption exceptions and destructive key approvals. No active exception is asserted.

Records and document control

Expected records include the risk register, asset inventory, assessment and approval records, training records, vendor reviews, access reviews, incidents, recovery exercises, findings and exception tickets. Store records in an access-restricted repository with ownership, version history and approved retention schedules. Preserve CD-ENC-001's minimum 12-month retention for KMS audit logs; do not generalize that period to all records. This sample contains no completed evidence or approval signatures.

Enforcement and annual review

Personnel must follow approved policy requirements and report suspected violations. Managers and CTO assess proportionate corrective action under applicable agreements and employment processes, with appropriate advice; no automatic sanction is asserted. Engineering Lead reviews this policy annually and after material incidents, business or technology changes. Record revisions, reviewer feedback and CTO approval before publishing an approved version. Current review_status: requires_user_review.